SUPPLIER SECURITY AND COMPLIANCE QUESTIONNAIRE
Issued by: Brightline Retail AD, Procurement Department
Supplier: Northwind Cloud Ltd.
Please answer every question. Attach evidence where requested. Return by 2026-11-20.

Section 1. Company and certifications
1.1 What is the full legal name and registration number of your company?
1.2 Is your company certified to ISO/IEC 27001? Please state the certification body and the expiry date.
1.3 Do you hold a SOC 2 Type II report? If yes, for which period?
1.4 How many employees does your company have?

Section 2. Data protection
2.1 In which countries is our data stored and processed?
2.2 Is customer data encrypted at rest and in transit? Describe the algorithms used.
2.3 Do you use subprocessors? Provide the current list.
2.4 Will you sign our Data Processing Agreement under Article 28 GDPR?
2.5 How quickly do you notify customers of a personal data breach?

Section 3. Operations and continuity
3.1 What uptime do you guarantee, and what service credits apply when it is missed?
3.2 How often are backups taken, and how long are they kept?
3.3 What are your recovery time objective (RTO) and recovery point objective (RPO)?
3.4 When was your last disaster recovery test, and what was the result?
3.5 Do you perform annual penetration tests by an independent company?

Section 4. People and access
4.1 Is multi-factor authentication enforced for all staff with access to customer data?
4.2 Are background checks performed on employees before hiring?
4.3 How often do employees receive security awareness training?
4.4 Describe your process for removing access when an employee leaves.

Section 5. Insurance
5.1 Do you carry cyber liability insurance? State the insurer and the amount of cover.